

Points de vigilance et sécurité

Contrôles, risques et procédures d’incident

Document	Référentiel sécurité
Version	Révision auditée — 23 août 2026
Périmètre	Portail interne BSO
Statut	Document de référence à valider

Contenu du document

- Données hors ligne et cash
- Rôles, invitations et RLS
- Intégrité et traçabilité

- Incidents et risques résiduels

Périmètre : données clients, opérations financières, appareils et Supabase

Révision : 23 août 2026

1. Principes prioritaires

1. Une donnée non synchronisée existe uniquement sur l'appareil : sa suppression peut être définitive.
2. Le Total Cash mesure le cash physique collecté; le solde officiel dépend de la validation comptable.
3. Un bouton masqué n'est pas une protection suffisante : les règles doivent aussi être imposées par Supabase.
4. Chaque utilisateur utilise son propre compte et son propre rôle.
5. Les données locales doivent disparaître lors de la déconnexion.
6. Un secret technique ne doit jamais être écrit dans le code, un document ou une capture d'écran.

2. Données hors ligne et risque de perte

File de synchronisation

Les opérations hors ligne restent dans **syncQueue** jusqu'à leur transmission. Les statuts importants sont :

- **pending** : en attente d'envoi;
- **failed** : tentative échouée, intervention requise;
- **completed** : envoi terminé.

Attention : **pending** dans **syncQueue** décrit l'état technique de l'envoi. **validation_status = pending** décrit l'état financier d'une transaction déjà enregistrée. Ces deux notions ne doivent pas être confondues.

Avant toute maintenance

Ne jamais vider ou remplacer la base locale avant d'avoir :

7. vérifié le nombre d'éléments **pending** et **failed**;
8. synchronisé;
9. confirmé que Supabase contient les opérations;
10. contrôlé les rapports concernés.

La fonction générale de suppression locale reste une action à haut risque. Elle doit être réservée au support ou accompagnée d'une procédure interne, car une simple confirmation utilisateur ne garantit pas qu'une sauvegarde existe.

Déconnexion

La déconnexion supprime volontairement la base métier, les journaux locaux, les caches sensibles et les informations de session. Si des éléments ne sont pas synchronisés, l'utilisateur reçoit un avertissement explicite.

Le choix recommandé est toujours : annuler, synchroniser, vérifier, puis se déconnecter.

3. Cash physique et soldes

Cash physique

Une entrée d'argent collectée apparaît dans le Total Cash dès sa saisie, qu'elle soit **pending** ou **confirmed**. C'est nécessaire pour que l'Agent remette le montant réellement présent dans sa caisse.

Une opération **rejected** est exclue du Total Cash.

Solde comptable

Un dépôt ou paiement en attente ne doit pas être présenté comme définitivement comptabilisé. Le serveur applique l'effet comptable lors de la confirmation.

Risques courants

Situation	Risque	Contrôle attendu
Confondre pending avec « cash non reçu »	Écart de caisse artificiel	Inclure le cash collecté dans le rapprochement
Confondre Total Cash et solde officiel	Information client incorrecte	Vérifier le statut de validation
Valider un lot sans filtrer l'Agent et la date	Validation d'opérations étrangères au dépôt	Contrôler filtre, période et nombre de lignes
Enregistrer le solde initial comme dépôt du jour	Total Cash surévalué	Utiliser is_solde_initial
Paiement supérieur au restant dû	Surpaiement et incohérence	Laisser le serveur refuser l'opération

4. Rôles et moindre privilège

Droits globaux

Admin, Manager et Finance peuvent modifier les données métier. Cette autorisation est volontaire et doit être compensée par :

- des comptes nominatifs;
- la protection des mots de passe;
- la revue des journaux;
- une procédure de correction et de suppression;
- le retrait rapide des accès lors d'un départ.

Agent

L'Agent peut consulter les données nécessaires au fonctionnement actuel du portail et créer les opérations de terrain. La modification ou suppression de données existantes protégées nécessite un accès temporaire actif accordé par un Admin.

Une dérogation doit rester :

- limitée à une ressource ou un client;
- limitée dans le temps;
- motivée;
- attribuée à un Agent identifié;
- consultable dans l'audit.

Rôle non défini

Le rôle 4 est bloqué dans l'interface et par la base. Il ne doit pas servir de rôle provisoire permettant de travailler.

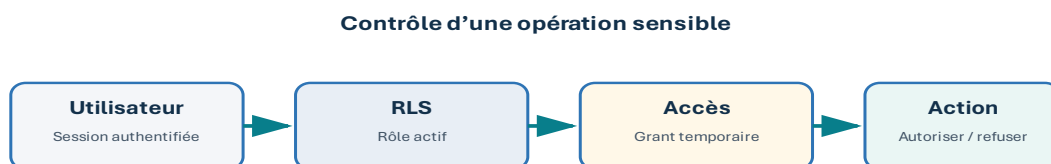
5. Invitations et comptes

- Admin et Manager peuvent générer des codes pour Manager, Agent et Finance.
- Aucun code ne peut attribuer le rôle Admin.
- Les codes expirent entre 1 et 30 jours et sont à usage unique.
- La consommation et l'attribution du rôle sont exécutées côté serveur.
- Les fonctions de génération, consommation et révocation ne sont pas accessibles au rôle anonyme.
- La validation préalable d'un code reste accessible avant inscription, ce qui est nécessaire au parcours utilisateur.

La création d'un Admin doit être exceptionnelle et réalisée par le responsable technique via une procédure documentée, avec validation de la direction et preuve d'audit.

6. Politiques Supabase vérifiées

Schéma 1 — Défense en profondeur des opérations sensibles



Le bouton de l'interface ne remplace jamais le contrôle PostgreSQL.

Audit : auteur • ressource • date • avant • après • motif

Les cinq tables métier principales disposent de politiques RLS distinctes pour **SELECT**, **INSERT**, **UPDATE** et **DELETE**.

État vérifié :

- aucune politique métier n'est attribuée à **public**;
- seuls les profils actifs peuvent lire les données métier;
- les insertions vérifient le rôle actif et l'auteur déclaré;
- Admin, Manager et Finance passent le contrôle d'écriture global;
- l'Agent passe uniquement si une dérogation active couvre la ressource;

- le rôle 4 et les utilisateurs anonymes sont refusés;
- `created_by` est conservé lors des modifications;
- la table `profiles` n'a plus de politique générale `true`.

7. Intégrité et traçabilité

Auteur de création

`created_by` représente la personne ayant créé l'enregistrement. Il ne doit pas être remplacé par l'auteur d'une correction ultérieure. L'application conserve la valeur d'origine et un trigger serveur empêche sa modification directe.

Audit

Les accès temporaires et actions sensibles doivent permettre de répondre à :

- qui a agi;
- sur quelle ressource;
- à quelle date;
- avec quelle autorisation;
- quelle était la valeur avant;
- quelle est la valeur après;
- quel motif a été donné.

Les journaux ne remplacent pas une procédure de revue. Le responsable désigné doit les consulter périodiquement.

8. Secrets et configuration

Sont considérés comme secrets :

- jetons Supabase Management `sbp_...`;
- clés de service `service_role`;
- mots de passe de base de données;
- clés de déploiement;
- jetons de plateformes tierces.

Règles :

- les fournir uniquement par un gestionnaire de secrets ou une variable d'environnement;
- ne jamais les placer dans Git, Markdown, Word, courriel ou messagerie non prévue;
- révoquer immédiatement un secret exposé;
- vérifier l'historique Git, pas seulement le fichier actuel;
- limiter la durée et les permissions du jeton.

9. Appareils et sessions

- Activer le verrouillage de l'appareil.
- Ne pas mémoriser le mot de passe dans un appareil partagé non maîtrisé.
- Se déconnecter avant de remettre l'appareil à une autre personne.
- Déclarer immédiatement la perte ou le vol.
- Invalider la session côté serveur lorsque cela est possible.
- Ne pas utiliser le portail sur un appareil rooté, jailbreaké ou non mis à jour sans décision de sécurité.

Le portail tente de limiter les sessions actives et nettoie la session locale à la déconnexion. Une indisponibilité réseau ne doit jamais empêcher la purge locale.

10. Procédures d'incident

Appareil perdu ou volé

11. Informer immédiatement Admin et responsable technique.
12. Invalider la session active.
13. Changer le mot de passe du compte.
14. Rechercher des opérations non reconnues.
15. Examiner les accès temporaires et journaux.
16. Documenter l'incident.

Jeton ou mot de passe exposé

17. Révoquer ou changer le secret.
18. Ne pas se contenter de supprimer le texte du fichier.
19. Rechercher son utilisation dans les journaux.
20. vérifier Git et les sauvegardes partagées;
21. créer un nouveau secret avec les droits minimums.

Écart de caisse

22. Ne pas valider tout le lot.
23. Isoler l'Agent et la période.
24. Comparer les lignes, carnets et montants physiques.
25. Identifier les opérations manquantes, dupliquées ou rejetées.
26. Conserver le motif et les preuves.
27. Faire approuver toute correction.

Synchronisation en échec

28. Conserver la session et les données locales.
29. Capturer le message d'erreur sans exposer de données sensibles.

30. Vérifier réseau, session et date de dernière synchronisation.
31. Réessayer.
32. Ne vider la base qu'après confirmation de la présence des données sur Supabase.